

Agent Passport Standards Series
APS 1001 (2026), revision 2
Series 1000: Payment Rails
Category: Proposed Standard

T. Cvikl
A. Tran
B. Liu
J. Burnazyan
Legis Labs Ltd
7 September 2026

APS 1001

Agent Passport Standard: Delegated Authority of Autonomous Agents on Payment Rails

Status of this Memo

APS 1001 specifies the procedure by which an autonomous software agent proves, before a payment executes, that it acts within a current, human-granted authority. It is a proposal for discussion, demonstrated on synthetic data. It does not describe a current legal requirement. Distribution is unlimited.

Revision 2 replaces the per-agent approval of revision 1 with a model register: the authority approves a model once, and every agent deployed on it inherits that approval under the authority's policy ceilings.

Abstract

An agent that can be identified can still act beyond what its principal allowed. This document separates identity from authority. An Agent Passport is an envelope of three signed claims, each made by the only party entitled to make it: the supervisory authority, which approved the model; the customer, which deployed an agent on that model; and the same customer, which signed the mandate the agent must stay within. A relying bank verifies the envelope and the signed instruction with an ordered, deny-by-default procedure and answers ALLOW, ESCALATE or DENY with a rule citation and a signed receipt. Authority may be delegated but never expanded. Revocation is a registry lookup. Every decision is replayable.

1. Introduction

Firms delegate invoice payment to AI agents. A bank receiving an instruction cannot determine which agent sent it, whether it was permitted to, or who answers for it. Since 2024, UK banks bear the loss when a misdirected payment is authorised. This standard gives the bank one verification call that answers those three questions before money moves, and gives the authority one approval per model rather than one per agent.

The key words MUST, MUST NOT, SHOULD and MAY are to be interpreted as described in RFC 2119.

2. Terminology

Authority	The supervisor that approves models, sets policy ceilings and maintains the status registry.
Provider	The AI company that registers a model. It attests the accuracy of the model's documentation and nothing else.
Model	A named, version-pinned AI system registered by a provider and approved by the authority.
Customer	The legal person whose funds an agent moves.
Agent	The customer's deployment of an approved model: a private key, a configuration, a mandate.
Relying party	The bank that executes payment instructions.
Passport	The envelope defined in Section 4. A passport that satisfies Sections 3 to 7 is APS 1001-conformant.

3. Registration and Approval

3.1 A provider MUST register a model before any agent is deployed on it. A registration MUST name the legal entity, a natural person attesting the documentation, the model and its pinned version, and locations of its benchmark data, training details and model card. A registration MUST NOT name a customer or contain any mandate content.

3.2 The authority MUST evaluate a registration against written checks and record each result with its source:

- M.1 registered company matches the companies register
- M.2 a named person attests the documentation
- M.3 model documented: name, identifier, provider, pinned version, documentation locations
- M.4 version pinned
- M.5 registered use within the authority's policy
- M.6 model not already on the register

Automated review MAY draft; a human officer MUST decide.

3.3 An approval MUST state the policy ceilings that every mandate on the model must satisfy (maximum per-payment limit, maximum rolling limit per payee account, maximum validity, permitted actions) and a supervisor condition (an amount above which the relying party holds the instruction for a named human).

3.4 An approval MAY be suspended or revoked. Either act MUST cascade to every passport issued on the model.

4. The Passport

A passport MUST consist of three signed tokens (JWT, RFC 7519; EdDSA, RFC 8037) and an identifier:

assurance	signed by the AUTHORITY: the approved model (registration reference, name, identifier, version), approval status, policy ceilings, supervisor condition, validity, registry pointer, and the hash of the agent_identity it was issued for.
agent_identity	signed by the CUSTOMER: agent name, the model it runs on, agent public key (cnf, RFC 7800), proof of possession, configuration hash, key custody.
mandate	signed by the CUSTOMER: permitted actions, payee allow-list by account, per-payment limit, rolling limit per payee account, expiry, as an authorization_details object (RFC 9396).

No party MAY alter a claim it did not sign. A passport carries permission, not personal data.

5. Issuance

- 5.1 A customer registers an agent by choosing an approved model, generating a key pair, proving possession of the private key by signing the authority's challenge, and signing agent_identity. This creates an agent record. It is not a passport.
- 5.2 The customer writes its mandate. Before signing, the system MUST check that every limit sits within the policy ceilings of the model's approval (containment). A mandate outside the ceilings MUST NOT be signed.
- 5.3 On signature of a contained mandate the authority's system MUST sign the assurance from the model approval, assign the passport identifier, set the registry status to ACTIVE and, where a purpose-bound rail is in use, mirror the mandate on it. No further human review takes place: the human decision was the model approval.

6. Verification Procedure

The agent MUST sign every instruction with the key named in agent_identity. The relying party MUST evaluate the following in order and stop at the first failure:

- R.1 assurance signature verifies (authority key)
- R.2 assurance ACTIVE and unexpired (registry lookup)

R.3 agent_identity verifies (customer key) and is bound to this assurance
 R.4 instruction signed by the agent key in agent_identity
 R.5 mandate present, customer-signed, unexpired
 R.6 action permitted; payee account on the allow-list
 R.7 amount within the per-payment limit
 R.8 amount plus the relying party's own rolling total within the limit per payee account
 R.9 amount above the supervisor condition -> ESCALATE
 else -> ALLOW

The result MUST cite the rule that decided it and MUST be accompanied by a receipt signed by the authority. Limits live in the mandate; running totals live at the relying party.

7. Delegation

Where an agent delegates to another, the delegation MUST be signed by the delegating key, and for scopes S0 (mandate), S1 ... Sn:

Sn is a subset of ... S1 is a subset of S0, and the action is an element of Sn.

Delegation MAY narrow authority. It MUST NOT expand it.

8. Lifecycle

Register	A provider registers a model (Section 3.1).
Approve	Checks M.1 to M.6 are run; adversarial cases are run through the procedure of Section 6; a human officer decides; the approval states ceilings and a condition.
Issue	A customer registers an agent and signs a contained mandate; the passport is issued at signing (Section 5).
Act	The relying party verifies each instruction.
Detect	Every refusal is recorded. A repeated refusal of the same rule SHOULD raise an alert to the authority.
Revoke	The authority sets the registry status of a passport or of a model. The next instruction fails at R.2 on every rail that mirrors the mandate.
Replay	Every decision MUST be reproducible from its recorded inputs.

9. Security Considerations

A copied passport is useless without the agent's private key (R.4). A forged or altered claim fails its signature (R.1, R.3, R.5). A manipulated agent that requests payment to an account the customer never listed fails R.6 regardless of how genuine the invoice appeared. A mandate cannot exceed the model's ceilings (Section 5.2), so a customer cannot grant what the authority did not allow. Compromise of the authority's key, and attestation of

the running software, are out of scope.

10. What APS 1001 Does Not Specify

Settlement. Know-your-customer, sanctions or funds checks. Whether a payment is wise. Liability of the provider for an agent's conduct: the provider attests documentation; the customer owns the mandate. Any judgement by a model: models read and draft; rules decide; humans sign.

11. References

APS 1002 (delegation chains, reserved), APS 2001 (tax rails, reserved), RFC 2119, RFC 7519 (JWT), RFC 7800 (cnf), RFC 8037 (EdDSA), RFC 9396 (Rich Authorization Requests), W3C Verifiable Credentials (JWT profile), NIST NCCoE 2026 (agent identity and authorization), FATF 2025 (AI and AML/CFT), HM Treasury (2026) Modernising Payment Services Regulation, Recommendation 10.

Authors' Addresses

Legis Labs Ltd, Cambridge, United Kingdom.
Reference implementation: <https://pay.cdir.legislabs.uk>
Source: <https://github.com/LegisLabs/agent-passport>